

MODULE 2 — User & Role Management

Version: 1.0

Status: Draft → Pending Confirmation

System: Omni-Channel CRM Platform

Audience: Product, Backend, Security, QA, Compliance

1. Module Overview & Objective

1.1 Purpose

This module governs **who can do what, where, and under which constraints** across the entire platform.

It is designed to:

- Enforce **strict access control**
- Enable **enterprise-grade flexibility**
- Maintain **full accountability and auditability**
- Avoid hardcoded roles and brittle assumptions

This is **not** a basic user system.

It is a **permission orchestration layer** built for AI-driven, multi-module SaaS.

2. Module Scope

This module applies uniformly across:

- CRM (Leads, Contacts, Companies, Deals)
- AI Calling
- Campaign Management
- Analytics & Dashboards
- Billing & Usage Visibility
- Administrative & Configuration Actions
- White-label identity management (included)

Scope enforcement is mandatory at **API level**, not UI level.

3. Role Model (Frozen Decisions)

3.1 Role Philosophy

- Roles are **tenant-defined**
- Permissions are **explicit and granular**
- No system assumption that:
 - Users = sales agents
 - AI agents belong to users
- AI entities and human users are **intentionally decoupled**

This design prevents the classic CRM failure of binding automation to individuals.

3.2 User Type Constraints

- **Named Users**
 - Maximum: 15 per tenant
 - Created and managed by Tenant Admin
 - **Concurrent Users**
 - Maximum: 5 active sessions at a time
 - Enforced at session/authentication layer
 - Excess concurrent logins must be blocked, not queued
-

4. Default System Roles (Seed Roles)

These roles are **templates**, not enforced contracts.

Role	Description
Super Admin	Platform owner, internal only
Tenant Admin	Full control within tenant boundary
Manager	Team oversight, approvals, analytics
Sales Agent	CRM execution + AI calling
Support Agent	Inbound & support workflows
Auditor	Read-only access across modules

Rules

- Tenants may:
 - Modify permissions
 - Clone roles
 - Create new roles
 - Delete unused roles
 - **Super Admin role cannot be modified or deleted**
 - Tenant Admin cannot grant Super Admin privileges
-

5. Permission Model (Core Design)

5.1 Permission Structure

Permissions are defined as:

Module → Submodule → Action

Examples:

- CRM → Leads → Edit
- AI Calling → Campaigns → Start
- Analytics → Dashboard → View
- Billing → Usage → View

This allows:

- Fine-grained access control
 - Permission changes without code deployment
 - Predictable security behavior
-

5.2 Permission Actions (Standardized Set)

Permissions must be explicitly assigned. No implied access.

Supported actions include:

- View
- Create
- Edit
- Delete

- Execute (calls, campaigns, workflows)
 - Approve (managerial actions)
 - Export
 - Configure
 - Communication / Notification
 - Attachment handling
 - Print
-

6. Custom Role Builder (Confirmed)

6.1 Functional Capabilities

Tenant Admin shall be able to:

- Create roles via UI
- Toggle permissions per module/submodule
- Clone existing roles
- Assign multiple roles to a single user (configurable)

Permission evaluation must resolve conflicts deterministically (deny overrides allow).

6.2 Hard Constraints

- No role may override Super Admin authority
 - Billing **write access** is restricted to **Tenant Admin only**
 - This restriction is enforced at API layer
-

7. User Management

7.1 User Lifecycle

Tenant Admin shall be able to:

- Create users
- Assign role(s)
- Activate / deactivate users
- Soft-delete users (audit-safe)

Hard deletion is not allowed via UI.

7.2 User Attributes

Each user record must include:

- Full Name
 - Email (unique per tenant; primary login identifier)
 - Phone number (optional)
 - Assigned role(s)
 - Account status
 - Last login timestamp
 - Activity summary (derived)
-

8. Authentication & Session Management

8.1 Authentication Mechanism

- Email + password login
 - Password policy:
 - Minimum length
 - Complexity rules
 - Password reset via email
 - Device-based authorization (Version 2)
 - Two-factor authentication (optional, configurable per tenant)
 - SSO is explicitly excluded in v1
-

8.2 Session Management

- Token-based authentication
 - Configurable session timeout
 - Tenant Admin can force logout users
 - Concurrent session limit enforced strictly
 - Session violations must terminate oldest session or deny new login (configurable)
-

9. Activity Logging & Audit

9.1 Logged Events

All actions below must be logged immutably:

- Login / logout
- Role assignment or change
- Permission modification
- Campaign start / stop
- Manual CRM edits
- AI overrides initiated by humans

Each module must maintain an **audit table** with:

- Actor (user / system)
- Action
- Timestamp
- Entity affected
- Source (UI / API)

Alternative audit architectures may be proposed separately.

9.2 Log Visibility

- Tenant Admin: tenant-level logs only
 - Super Admin: platform-wide logs
 - Logs are read-only and immutable
-

10. AI Agent vs User Boundary (Critical)

10.1 Confirmed Behavior

- AI agents are system entities
 - AI actions are driven by campaigns and rules
 - AI agents do **not** belong to users
-

10.2 Attribution Rules

Every AI action must be tagged with:

- AI Agent ID
- Campaign ID
- Tenant ID

This ensures:

- Clear accountability
- Clean analytics
- No human blame ambiguity

11. Security Rules (Hard Constraints)

The system must enforce the following without exception:

- Users cannot escalate their own roles
- Users cannot modify roles assigned to themselves
- Tenant Admin cannot access Super Admin capabilities
- No cross-tenant user visibility
- All violations must be blocked at **API level**

UI-only enforcement is considered a security failure.

Stakeholders

1. Hitech solution Admin → full access
2. Hitech Power Users →
3. Customer Admin → full access
4. Customer Power Users
5. Sales/marketing Team (More mobile friendly)
6. Distributor team (customer ka customer) → customer portal

Story

1. Hitech solution → Company admin
2. Techavtar → customer admin
3. Jio → Distributor